

June 22, 2026 Security

Patch the Planet: a Daybreak initiative to support open source maintainers

▶ Listen to article | 11:06

🔗 Share

We are introducing Patch the Planet, a Daybreak initiative built with Trail of Bits to help maintainers strengthen the critical open-source software the world relies on. We're pairing AI-assisted security research using our most cyber-capable models with expert human review to not only identify vulnerabilities, but help patch them.

AI is accelerating vulnerability discovery, but discovery alone does not protect users. Many maintainers are already being asked to sort through more reports, more quickly, with the same limited time and resources. Patch the Planet is built to reduce that burden, not add to it: security engineers review findings before they reach maintainers, work with projects to develop patches and tests, and build reusable workflows that help teams continue improving security after the first fixes land.

Trail of Bits has committed their entire security research organization towards this effort for our initial surge. They are working directly with maintainers to investigate and validate vulnerabilities, develop and test patches, and coordinate disclosure of vulnerabilities.

Additionally, we will be partnering with HackerOne and Calif who are helping us take our efforts further with vulnerability triage, coordinated disclosure, and additional focused vulnerability discovery efforts.

How Patch the Planet works

Each engagement under Patch the Planet begins in consultation with the maintainer. For each collaboration, security engineers work with maintainers to understand each project's needs, preferences, and where additional security effort would be most useful: vulnerability validation, patch development, CI/CD improvements, or longer-term security engineering. Once aligned, researchers investigate potential vulnerabilities, validate meaningful issues, develop or refine patches, support testing, and coordinate disclosure through the project's established channels.

Initial participants include cURL, NATS Server, pyca/cryptography, Sigstore, aiohttp, the Go project, freenginx, Python, and python.org. These projects support widely used networking, cryptography, software supply chain, and language infrastructure, where stronger security can benefit a broad range of downstream products and services. Additional projects will join in future rounds.

Security researchers are equipped with our frontier models as well as Codex Security to support the analysis, patch development, testing, and documentation. Participating projects receive access to ChatGPT Pro; conditional access to Codex Security; and API credits for core open-source development, maintainer automation, and release workflows. Trail of Bits has developed AI-assisted workflows for deduplication, triage, and patching that projects can run with this support.

Early field notes and findings from developers

Trail of Bits has dedicated security engineers to work full-time with Codex and GPT-5.5-Cyber across 19 open-source projects, and has already identified hundreds of security issues and merged dozens of patches, with many more still undergoing coordinated disclosure.

The initial sprint also produced reusable security infrastructure: fuzzing harnesses, historical-CVE analysis pipelines, differential-testing systems, threat models, expanded test suites, and workflows for deduplication, false-positive filtering, severity correction, and patch generation. Some project-specific details will be shared later as testing,

OpenAI

A fuzzing lab in less than a day. Trail of Bits engineers used repeated Codex /goal runs with GPT-5.5-Cyber to build an entire fuzzing lab covering dozens of entry points, variant builds, platforms, and novel test seeds. Engineers set the objectives and refined the prompts; the system then used coverage feedback to keep expanding into new surfaces, target edge cases, and filter weak or invalid candidates.

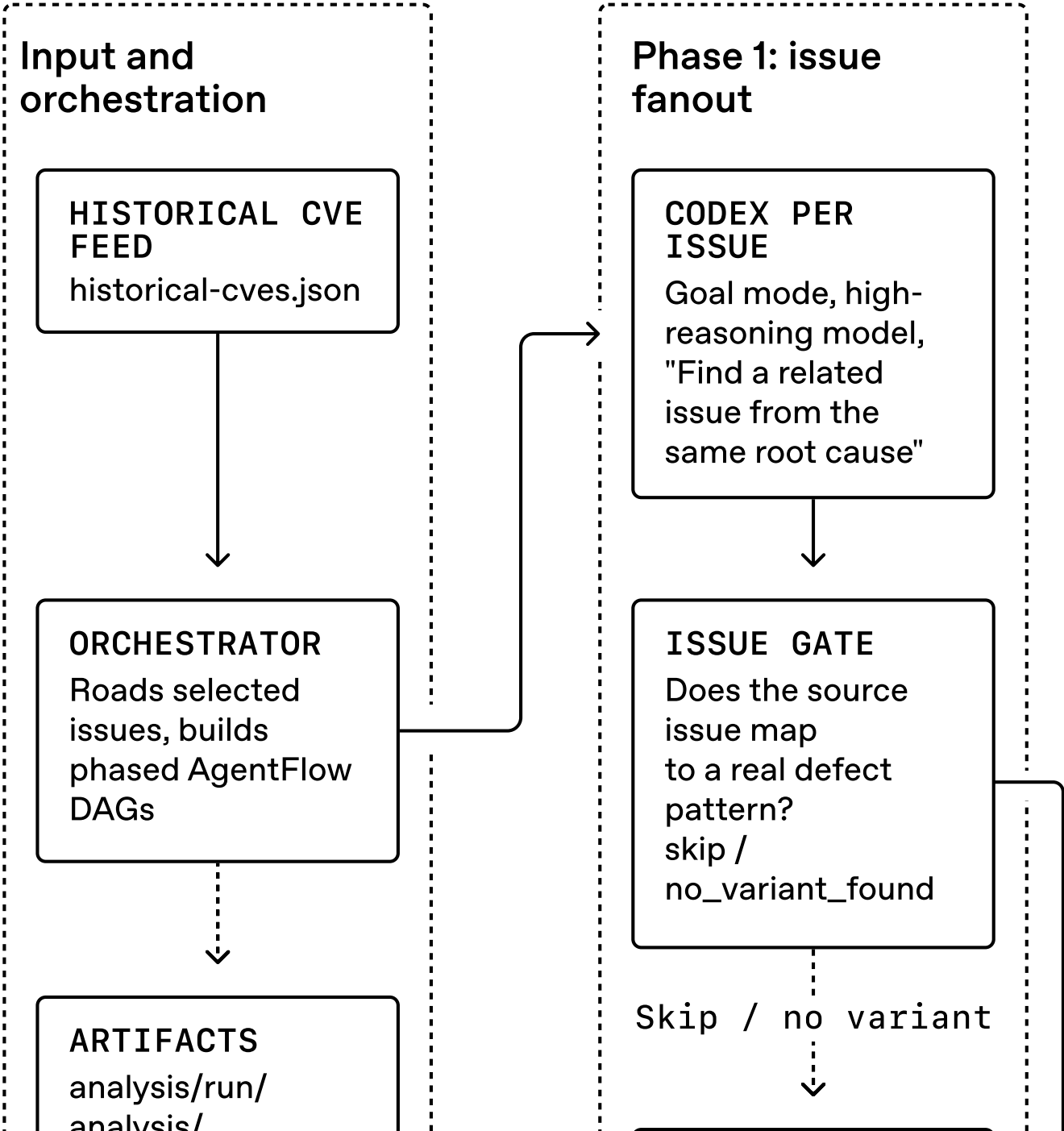
Trail of Bits engineers found that, with limited guidance, GPT-5.5-Cyber made useful choices about where to expand coverage, which builds and entry points to probe, and which candidates were too weak to pursue. The completed setup took less than a day. Trail of Bits estimates that building the same lab manually would ordinarily take at least several weeks.

A reusable pipeline for finding variants of known vulnerabilities. The team built an end-to-end system that ingests historical CVEs, extracts relevant vulnerability patterns, searches target codebases for related flaws, and sends candidate findings through specialized judging agents. The pipeline deduplicates results, filters likely false positives, and routes the strongest evidence to security engineers for manual confirmation.

This turns years of public vulnerability history into a repeatable search strategy that can be applied across projects. Trail of Bits found the models especially effective at this kind of variant analysis, which uncovered many additional issues across the codebases under review.



Historical CVE-Driven variant discovery and validation



Differential testing in days instead of weeks or months. Different implementations of the same protocol should usually behave the same way under the same inputs. When

OpenAI

implementation to a common test harness.

Codex generated and iterated on that code, allowing multiple implementations to be fuzzed against one another and their behavioral differences investigated. The workflow filtered many weak or invalid results and produced a comparatively high-signal set of candidates for expert review. The team reached those results within days, compressing work that has historically taken weeks or months. Trail of Bits is continuing to expand and refine these tests before publishing project-specific details.

Testing software against the behavior its specifications promise. The teams used Codex to develop threat models, attack taxonomies, invariant tests, and property-based tests grounded in project specifications and RFCs. These methods exposed notable differences between intended and actual behavior while leaving projects with broader test coverage, stronger documentation, and improvements to CI/CD and software-supply-chain tooling.

Security engineers reviewed every finding before it reached a maintainer. Trail of Bits engineers manually reviewed every security issue before it was submitted to a maintainer, and the added value of this step cannot be understated. While frontier AI models are highly capable of finding vulnerabilities and patching them, they also produce a high volume of false positives that can contribute to the already overwhelming backlog maintainers are facing. Patch the Planet solves for this by having dedicated Trail of Bits researchers reproduce the evidence, check findings against project-specific documentation and threat models, remove duplicates, reassess severity, and prioritize confirmed vulnerabilities for remediation. They also develop and submit patches in accordance with maintainers preferences. Maintainers remain in control of what patches are deployed and how disclosure is handled.

What OpenAI Daybreak is already finding

Patch the Planet builds on a broader body of Daybreak work showing how frontier models can help defenders find, validate, and remediate serious vulnerabilities in widely used software.

OpenAI

project-specific details where disclosure is still underway. As fixes land and coordinated disclosures conclude, we plan to publish deeper technical reports that walk through individual findings, research methods, validation workflows, and lessons other defenders can apply.

Our findings span every layer of the software stack, with many more still in the disclosure process.

Operating systems

- **Linux Kernel:** GPT-5.5-Cyber identified security-relevant components across more than 30 million lines of code, flagged potential security issues, and then validated them dynamically, generating 8 kernel pointer information leak proof-of-concepts (PoCs) and 24 local privilege escalation exploits. We note that hundreds of issues were identified, this is the subset for which PoCs were automatically generated.
- **OpenBSD:** Our models identified a 23-year-old use-after-free in OpenBSD's kernel implementation of System V semaphores. OpenAI researchers reproduced the issue and confirmed that it could allow an unprivileged local user to escalate privileges to root.
- **FreeBSD:** Security researchers at Calif used Codex to find and validate using proof-of-concept exploits for several LPEs in FreeBSD. Across a broader FreeBSD campaign, OpenAI researchers confirmed 34 vulnerabilities and produced 7 local privilege escalation PoCs.

Network

- **dnsmasq:** Codex Security independently identified vulnerable patterns corresponding to four of the six dnsmasq CVEs later fixed in 2.92re12 : CVE-2026-4890, CVE-2026-4891, CVE-2026-4892, and CVE-2026-5172.
- **HTTP/2 Bomb:** Calif used Codex to identify "HTTP/2 Bomb," a denial-of-service technique affecting major HTTP/2 implementations including NGINX, Apache, IIS

OpenAI

Browsers

- **Chrome:** OpenAI researchers found and reported five exploitable vulnerabilities in Chrome's V8 JavaScript engine, including three that were identified and remediated within days of being introduced.
- **Safari:** In roughly a week of focused WebKit work, over 10 exploitable Safari vulnerabilities were found and reported.
- **Firefox:** OpenAI Preparedness identified a WebAssembly vulnerability ([CVE-2026-8390](#)) with GPT-5.5 during [safety evaluations](#) that Mozilla patched two days before Pwn2Own Berlin, prompting five of six registered Firefox entries to withdraw. No Firefox exploit was successfully demonstrated at the competition.

Shared infrastructure, shared defense

Open-source software is shared infrastructure. Securing it should be shared work. AI is changing the pace of vulnerability discovery, and the work now is to make sure the benefits reach the maintainers and users who need them most.

Patch the Planet is designed to put that full defensive loop in service of maintainers: discovery, validation, severity review, disclosure, patch development, testing, and deployment. Frontier models can make parts of that loop faster, but the aim is to give the people responsible for shared infrastructure better tools and more capacity, while preserving their agency over how changes land.

This first sprint shows what sustained collaboration among maintainers, security engineers, and AI-assisted workflows can produce: immediate fixes, stronger project infrastructure, and reusable security work that can continue improving open-source software over time.

This is just the beginning. As more fixes land and coordinated disclosures complete, we plan to publish deeper technical reports on selected findings, the methods used to discover and validate them, and the workflows defenders can adapt to help protect the

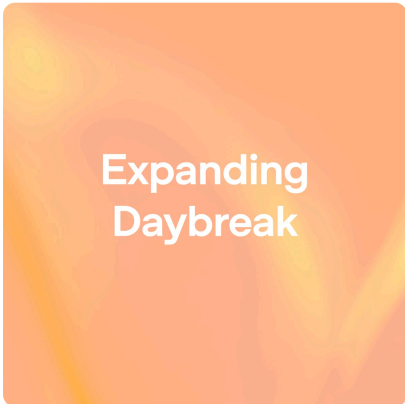
2026

Author

OpenAI

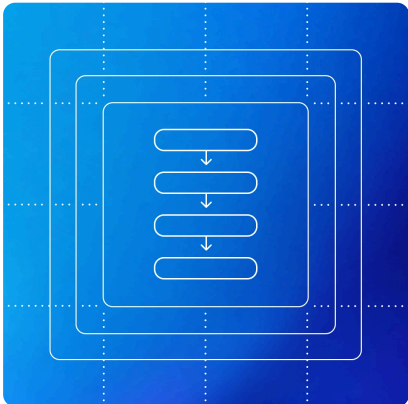
Keep reading

View all



Daybreak: Tools for securing every organization in the world

Security Jun 22, 2026



Building a safe, effective sandbox to enable Codex on Windows

Engineering May 13, 2026



Our response to the TanStack npm supply chain attack

Company May 13, 2026

Research

Research Index

Research Overview

Products

ChatGPT ↗

Business

Overview

Solutions

Company

About Us

Our Charter

More

Stories

Academy

Latest Advancements	ChatGPT Enterprise ↗	Partner Network	RSS
	ChatGPT for Education ↗	Contact Sales	Support
		Help Center ↗	Terms & Policies
	Codex	Developers	Terms of Use
	Release Notes	Apps SDK ↗	Privacy Policy
Safety		Open Models	Other Policies
	API Platform	Docs ↗	
	Overview	Resources ↗	
	API Log In ↗	Developer Forum ↗	
	Docs ↗		
Deployment Safety ↗			
Security & Privacy			
Trust & Transparency			